COLORADO
Information Security
Governor's Office of Information Technology

TS-CISO-007: Server Hardening

Document ID	TS-CISO-007
Title	Server Hardening
Executive Sponsor	Jill Fraser, Chief Information Security Officer
Issuing Authority	Governor's Office of Information Technology (OIT)
Applies to	All servers deployed or managed by the Governor's Office of Information Technology (OIT) for all supported agencies, including new servers, existing servers previously deployed at an agency, domain and non-domain servers, and virtual and physical servers.
Instrument Type	Standard
Version	1.0
Effective Date	04/28/2026
Last Updated	05/05/2026

Purpose

This standard is issued under the authority of the Governor's Office of Information Technology (OIT) (C.R.S. 24-37.5, et seq.) and the Office of Enterprise Architecture (Rule 8 CCR 1501-7). It defines requirements for securely configuring and hardening State server infrastructure to improve its defense and sustainability.

Scope

These standards apply to OIT, state agencies as defined in C.R.S. 24-37.5-101(28), and vendors contracted by OIT or its stakeholders, as a means to enforce technology standardization and assist in making the usage, support, and/or purchase of technologies more consistent and efficient.

Standards instituted for use by approval of the OIT Architecture Review Board (ARB) govern purchase and deployment decisions deemed "go-forward" or "net-new", and are not intended as a retroactively enforceable mandate for immediate conformance, especially where cost implications may be prohibitive. This standard shall in no way require OIT to support any products and services not approved by OIT.

This standard applies to all servers deployed or managed by OIT for all supported agencies, including:

- New servers
- Existing servers that were previously deployed at an agency
- Domain and non-domain servers
- Virtual and physical servers

Roles and Responsibilities

Enterprise Architecture - Chief Enterprise Architect

- Chairs and conducts business of the Architecture Review Board (ARB).
- Updates effective date and/or last review date.
- Publishes the ARB-approved Standard to the OIT public-facing website.

Architecture Review Board (ARB)

- Engages stakeholders and subject matter experts to determine standards.
- Reviews/approves the Standard (this document).

Server Support

- Implements server hardening procedures on all in-scope servers and maintains records thereof.
- Supports and documents this Standard and the server hardening process.

Vendors and Additional Staffing

- Comply with this Standard through all phases of work involving in-scope servers.
- Provide compliance reporting on request from OIT.

Standards

Server Hardening

- Refer to and implement current Center for Internet Security (CIS) benchmarks for all in-scope servers.

Server hardening will be achieved by:

- Using the Server Hardened VM Template.
- Applying local security policies and default domain GPOs.
- Applying a Linux Server Hardened template and/or the applicable Red Hat security baseline.
- Allowing for current application-specific approved exceptions.
- Allowing for current enterprise exceptions.

Communication and Documentation

Server hardening process documentation will be stored in the ServiceHub knowledge base.

Change Management

Changes to servers must be made in accordance with the OIT Change Management policy.

Policy Exception Requests

Requests for variances from any provisions within this Standard must be submitted via a Policy Exception Request.

Server Benchmark Review

The Server Support team will, on a quarterly basis:

- Review latest server benchmarks and implement any needed changes to the domain GPOs, local security policies, and VM templates.
- Review Enterprise exceptions and determine if any can be remediated or need to be re-submitted to the Office of Security Administration for another one-year exception.
- Address the OS patches that need to be applied to virtual templates.

Exceptions and Variance

All exceptions must be documented, justified, and approved by the State of Colorado's Chief Information Security Officer (CISO) or other designated authority. Compensating controls must be documented, implemented, and maintained.

Compliance

The State of Colorado's Chief Information Security Officer (CISO) or other designated authority will monitor and advise on compliance with this standard.

References

- Center for Internet Security
- Common Vulnerability Scoring System (CVSS)
- IRS Safeguards Program, CJIS Security Policy, SSA Secure Info Systems, HIPAA/HiTECH, and other applicable regulations
- CFR § 229.106 (Item 106) Cybersecurity

Definitions

- Change: The addition, modification, or removal of anything that could have an effect on IT services.
- Change management: The structured practice of controlling and communicating modifications within the IT environment.
- CIS: Center for Internet Security.
- Group Policy Object (GPO): A virtual collection of policy settings.
- HIPAA/HiTECH: Health Information Portability and Accountability Act; Health Information Technology for Economic and Clinical Health.